금융보안원 FINANCIAL SECURITY INSTITUTE	보 도 자 료 배포시부터 보도 가능	배 포 일 2026. 2. 10.[화]

작성부서	보안연구부 자율보안연구팀		
책 임 자	팀장 김태완 (02-3495-9720)	담 당 자	수석 이대규 (02-3495-9721)

제목 : 금융보안원, 금융보안 수준 진단 서비스 본격 실시

◈ **금융회사가 보안 수준을 스스로 진단(4단계)·개선할 수 있도록 「금융보안 수준진단 프레임워크」 개발·배포**

◈ **금융회사의 보안 수준 진단을 지원하기 위해 전담조직을 신설하였으며('26.1월), '26.3월부터 본격적으로 수준 진단 서비스 제공**

□ **금융보안원**(원장 박상원)은 금융회사가 자사 **보안 수준**을 정밀하게 **진단**하고 부족한 부분을 체계적으로 **개선**해 나갈 수 있도록 「**금융보안 수준진단 프레임워크**」를 **개발**하여 **배포**

□ 본 프레임워크는 150여 개 해외 금융회사 등이 참여한 **글로벌 금융보안 표준 진단 도구**인 CRI Profile **등**을 **참조**하였으며, 금융보안원이 **약 5개월간 20개 금융회사**와 **작업반**을 구성하여 심도 있는 논의와 **시범 테스트**를 거쳐 개발

□ 「**금융보안 수준진단 프레임워크**」는 ▲거버넌스, ▲식별, ▲보호, ▲탐지, ▲대응, ▲복구, ▲공급망의 총 **7개 분야 45개 항목, 127개 세부 원칙**으로 **구성**되어 **보안 전 분야**에 대한 **종합적 수준 진단**이 가능

○ **보안 수준**은 **초기**(Initial) → **기반**(Defined) → **발전**(Managed) → **고도화**(Advanced)의 **4단계**로 **평가**

○ **금융회사가 평균 수준**의 **보안 체계**를 갖추고 있는 경우 **2단계**인 **'기반'** 등급을 받도록 설계하였으며, 보안 수준을 높이면 **'발전', '고도화'로 등급이 상향** 되는 등, 금융회사가 현실에 안주하지 않고 **더 높은 보안 수준을 목표로 개선해 나가도록 유도**하는 것이 특징

※ 금융보안원 시범테스트 결과, 국내 대형 금융회사는 우수한 보안 체계를 갖추고 있어 평균 3단계(발전) 수준인 것으로 파악 (글로벌 금융회사는 3.5단계 이상 예상)

○ 또한, **기존 보안 진단**이 대부분 **체크리스트** 기반으로 이행 여부를 **예·아니오(Y/N) 방식**으로 단순 점검하는 데 반해, 금융보안 수준 진단은 **현재**의 **보안 수준**(As-is)을 진단하고 이를 토대로 **목표**(To-be)를 **설정**하고 **개선 방안**을 **제시**한다는 점이 **차별화**

【 금융보안 수준진단 프레임워크 】

□ **금융보안원**은 「금융보안 수준 진단 프레임워크」가 **금융권**에 **성공적**으로 **안착**할 수 있도록, 정책·기술 분야 **보안 전문가 7인**으로 구성된 **전담 조직**(자율보안연구팀)을 **신설**하였으며('26.1월), '26.3월부터 희망하는 금융회사를 중심으로 **현장 방문 진단 서비스**를 본격적으로 **제공**할 계획

ㅇ 아울러, 금융회사가 본 프레임워크를 **효과적**으로 **활용**할 수 있도록 **세부 진단 방법**과 **보안 모범사례 등**을 담은 **가이드**도 함께 **제공**하여 금융권 전반의 **보안 역량 강화**에 기여

□ '26년은 **금융보안 수준 진단 서비스 원년**인 만큼, 금융보안원은 **현장 방문 진단, 모범사례 수집** 등을 통해 **프레임워크**를 **고도화**하는 데 **주력**하고,

ㅇ 내년부터는 금융회사가 외부의 도움 없이 자체적으로 **보안 수준**을 **진단·개선**해 나갈 수 있도록 그간의 업무 노하우를 바탕으로 **자문**이나 **검증, 교육** 등 보다 **다각적인 지원 체계**를 **구축**해 나가는 등 **자율보안 체계가 금융권에 정착**해 나가는데 일조할 계획

□ 금융보안원 박상원 원장은 "**망분리 규제 완화**와 **AI 전환(AX)** 등 **급변**하는 **금융 IT 환경** 속에서 **새로운 보안 위협**에 **선제적**으로 **대응**하기 위해서는, 금융회사가 **주도적**으로 **보안**을 **계획**하고 **실천**하는 **자율보안 역량 확보**가 무엇보다 **중요**하다." 며,

ㅇ "금융보안원은 **금융회사 스스로 보안 수준**을 **진단**하고 **개선**하는 **선진화**된 **자율보안 문화**가 금융 현장에 뿌리내릴 수 있도록 **최선**을 다하겠다." 고 밝힘. 끝.

※ 「금융보안 수준진단 프레임워크」 및 가이드 전문은 금융보안 레그테크 포털(regtech.fsec.or.kr)에서 확인 가능

별첨 **금융보안 수준진단 프레임워크 주요 내용**

□ **(목적)** 금융회사가 **자사 환경**에 맞는 **보안 체계**를 **마련**하고, **스스로 진단·개선**하는 **선진화된 자율보안 문화 형성**

□ **(내용)** 거버넌스부터 탐지, 대응, 복구 등 **보안 全 분야**에 대한 **수준**을 **진단 (7개 분야, 45개 항목, 127개 세부 원칙)**

[「금융보안 수준진단 프레임워크」 진단 분야 및 항목]

분야	항목	세부 원칙	주요 내용
거버넌스	8개	27개	회사 보안 체계(전략 및 정책, 보안 조직, 교육 등)를 마련하고 경영진이 보안의 최종 책임
식별	5개	14개	해킹 등으로부터 보호 대상인 자산을 식별하고, 자산에 대한 위험을 상시 모니터링
보호	20개	54개	보안사고 예방을 위한 내부통제 활동(인증, 접근통제, 데이터 보호, 암호화, 악성코드 차단 등) 수행
탐지	5개	12개	보안 위협을 적시에 발견하기 위해 외부로부터의 전자적 침해 및 내부자 이상 행위 등을 모니터링
대응	4개	11개	보안사고 발생 시 체계적인 대응을 위해 계획을 마련하고 사고 대응훈련 등 수행
복구	1개	4개	보안사고 발생 시 신속한 복구를 위한 계획 수립 및 복구 결과 점검
공급망	2개	5개	클라우드 등 제3자 리스크 관리를 위한 방안 (제3자 계약, 보안 관리 등)
합계	45개	127개	-

○ 보안 수준은 **초기**(Initial) → **기반**(Defined) → **발전**(Managed) → **고도화**(Advanced)의 **4단계**로 측정

[보안수준 단계별 내용]

단 계	단계 내용
초기(Initial)	보안 활동이 비체계적 또는 임시로 구성
기반(Defined)	보안 체계를 구축하여 안정적으로 운영
발전(Managed)	보안 체계가 정교하여 대내외 환경 변화에 효과적으로 대응
고도화(Advanced)	전사적 차원에서 보안이 내재화(모범사례 수준의 고도화된 역량 확보)

□ **(특징)** 현재 취약 요인을 찾는 **단편적 진단·평가**가 아닌 **금융회사** 전반의 **보안 수준**을 **파악**하고 이를 **상향**해가는 것이 **목적**

※ 기존 단편적 진단·평가제도(취약점 분석·평가, ISMS-P 인증 등)와는 상이

[기존 진단·평가 체계와 보안수준 진단과의 차이점]

구 분	기존 진단·평가(취약점 분석·평가 등)	보안수준 진단
내용	현재의 취약점 및 미흡사항 파악	보안체계 전반에 대한 수준을 파악
예시	시스템별 취약점에 대한 보안패치 이행 여부(Y/N) 확인	취약점 및 보안패치 수행 체계의 수준을 확인(패치 방법, 절차 등)
활용	발견된 취약점 및 미흡 사항 조치	경영진 보고를 통해 보안투자 확대의 근거(Base) 자료로 활용 가능